

Checklist OWASP ASVS v4.0.3 ; 14 catégories

Présentation

L'OWASP ASVS v4.0.3 définit trois niveaux de profondeur pour l'évaluation de la sécurité applicative. Dans MUSA, le niveau est choisi selon la criticité de l'application (GIDOCEP = niveau 2). Les colonnes **N1/N2/N3** indiquent si le contrôle s'applique à chaque niveau. La colonne **Éval.** reçoit : C (Conforme), NC (Non conforme), ZG (Zone Grise), NA (Non applicable).

V1 : Architecture, conception et modélisation des menaces

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
1.1.1	Architecture documentée avec séparation des composants	—	✓	✓		
1.1.2	Modélisation des menaces réalisée pour les fonctions critiques	—	✓	✓		
1.1.3	Tous composants tiers identifiés et gérés	—	✓	✓		
1.1.4	Principe de moindre privilège appliqué	—	✓	✓		
1.1.5	Surface d'attaque documentée et minimisée	—	✓	✓		
1.1.6	Contrôles de sécurité centralisés (pas ad hoc)	—	✓	✓		

V2 : Authentification

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
2.1.1	Mots de passe d'au moins 12 caractères exigés	✓	✓	✓		
2.1.2	Mots de passe non tronqués à 64 caractères	✓	✓	✓		
2.1.3	Aucune rotation périodique forcée sans compromis connu	✓	✓	✓		
2.1.4	Blocage après 10 tentatives échouées	✓	✓	✓		
2.1.5	Mots de passe stockés avec hachage résistant (bcrypt/Argon2)	✓	✓	✓		
2.2.1	MFA disponible pour tous les comptes	—	✓	✓		
2.2.2	Codes OTP à usage unique implémentés correctement	—	✓	✓		
2.3.1	Identifiants initiaux changés dès première connexion	✓	✓	✓		
2.4.1	Processus de récupération de compte sécurisé	✓	✓	✓		
2.5.1	Pas de mots de passe dans les URL	✓	✓	✓		

V3 : Gestion de session

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
3.1.1	Identifiants de session créés côté serveur uniquement	✓	✓	✓		
3.2.1	Session invalidée à la déconnexion	✓	✓	✓		
3.2.2	Session expirée après inactivité (≤ 30 min)	✓	✓	✓		
3.2.3	Session régénérée après authentification réussie	✓	✓	✓		
3.3.1	Cookies avec attributs Secure, HttpOnly, SameSite	✓	✓	✓		
3.4.1	Durée de vie absolue des sessions limitée (≤ 12 h)	—	✓	✓		

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
3.5.1	Tokens JWT validés correctement (signature, expiration)	—	✓	✓		

V4 : Contrôle d'accès

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
4.1.1	Principe de refus par défaut (deny-all)	✓	✓	✓		
4.1.2	Contrôles d'accès vérifiés côté serveur uniquement	✓	✓	✓		
4.1.3	Accès aux fonctions sensibles protégé	✓	✓	✓		
4.2.1	Accès aux données vérifiés pour chaque utilisateur	✓	✓	✓		
4.2.2	Protection contre IDOR (Insecure Direct Object Reference)	✓	✓	✓		
4.3.1	Interface d'administration accessible uniquement aux admins	✓	✓	✓		
4.3.2	Interfaces d'administration avec IP restreinte	—	✓	✓		

V5 : Validation, nettoyage et encodage des entrées

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
5.1.1	Protection contre les attaques de paramètres HTTP	✓	✓	✓		
5.1.2	Framework protégeant contre les injections de masse	✓	✓	✓		
5.2.1	Encodage des sorties HTML (prévention XSS)	✓	✓	✓		
5.2.2	Prévention XSS pour JSON/XML	✓	✓	✓		
5.3.1	Prévention des injections SQL (requêtes préparées/ORM)	✓	✓	✓		

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
5.3.2	Protection contre les injections OS, LDAP, XPATH	—	✓	✓		
5.4.1	Validation de la mémoire (protection buffer overflow)	—	—	✓		
5.5.1	Désérialisation sécurisée	—	✓	✓		

V6 : Cryptographie

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
6.1.1	Données sensibles classifiées et protégées	✓	✓	✓		
6.2.1	Algorithmes cryptographiques approuvés utilisés	✓	✓	✓		
6.2.2	AES 128/256, RSA 2048+, SHA-256+ utilisés	—	✓	✓		
6.2.3	Mode de chiffrement sécurisé (pas ECB)	—	✓	✓		
6.3.1	Nombres aléatoires cryptographiquement sûrs	—	✓	✓		
6.4.1	Clés cryptographiques gérées de façon sécurisée	—	✓	✓		

V7 : Gestion des erreurs et journalisation

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
7.1.1	Aucune information sensible dans les journaux	✓	✓	✓		
7.1.2	Journaux horodatés avec source fiable	✓	✓	✓		
7.2.1	Événements de sécurité journalisés (auth, accès admin)	✓	✓	✓		
7.2.2	Avertissements de sécurité journalisés	—	✓	✓		

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
7.3.1	Messages d'erreur sans informations techniques	✓	✓	✓		
7.3.2	Traces de débogage désactivées en production	✓	✓	✓		
7.4.1	Journaux protégés contre la modification	—	✓	✓		

V8 : Protection des données

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
8.1.1	Données sensibles non mises en cache côté client	✓	✓	✓		
8.2.1	Données PII protégées selon les lois applicables	✓	✓	✓		
8.3.1	Données envoyées vers serveurs tiers identifiées	—	✓	✓		
8.3.2	Données sensibles chiffrées en transit	✓	✓	✓		
8.3.3	Données sensibles chiffrées au repos	—	✓	✓		

V9 : Communications

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
9.1.1	TLS utilisé pour toutes les communications sensibles	✓	✓	✓		
9.1.2	TLS 1.2+ uniquement (TLS 1.0/1.1 désactivé)	✓	✓	✓		
9.1.3	Suites cryptographiques fortes configurées	✓	✓	✓		
9.2.1	Certificats valides, non expirés	✓	✓	✓		
9.2.2	Validation complète du certificat	—	✓	✓		

V10 : Code malveillant

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
10.1.1	Pas de backdoor ni code malveillant dans l'application	—	✓	✓		
10.2.1	Intégrité des fichiers critiques vérifiable	—	✓	✓		
10.3.1	Mises à jour applicatives sécurisées et signées	—	—	✓		

V11 : Logique métier

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
11.1.1	Flux métier ne pouvant pas être contournés	✓	✓	✓		
11.1.2	Limites de valeurs vérifiées côté serveur	✓	✓	✓		
11.1.3	Protection contre les abus de vitesse (rate limiting)	—	✓	✓		
11.1.4	Données métier sensibles non exposées sans autorisation	✓	✓	✓		

V12 : Fichiers et ressources

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
12.1.1	Téléchargements limités en taille	✓	✓	✓		
12.2.1	Types de fichiers vérifiés (pas uniquement l'extension)	—	✓	✓		
12.3.1	Fichiers téléchargés stockés hors de la racine web	✓	✓	✓		
12.4.1	Prévention des inclusions de fichiers locaux (LFI/RFI)	✓	✓	✓		

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
12.5.1	Protection contre le parcours de répertoires	✓	✓	✓		

V13 : API et services web

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
13.1.1	Vérification que les appels API utilisent la même session	✓	✓	✓		
13.2.1	Protection contre les méthodes HTTP non autorisées	✓	✓	✓		
13.2.2	Protection CSRF pour les appels étatiques	✓	✓	✓		
13.3.1	APIs REST retournant les en-têtes de sécurité appropriés	—	✓	✓		
13.4.1	API GraphQL limitant les requêtes imbriquées	—	✓	✓		

V14 : Configuration

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
14.1.1	Pipeline de build documenté et sécurisé	—	✓	✓		
14.2.1	Composants tiers vérifiés (vulnérabilités connues)	✓	✓	✓		
14.2.2	Toutes les bibliothèques tierces maintenues à jour	✓	✓	✓		
14.3.1	Pas d'informations sensibles dans les en-têtes HTTP	✓	✓	✓		
14.3.2	En-têtes de sécurité HTTP configurés (CSP, HSTS, X-Frame)	✓	✓	✓		
14.4.1	Cookies avec politique SameSite appropriée	✓	✓	✓		

Réf.	Contrôle	N1	N2	N3	Éval. preuve	+
14.5.1	CORS configuré de façon restrictive	✓	✓	✓		